

Task–Skill Consistency, Skill-Carried Authorization Context, and Trace-Guided Repair in the OpenClaw Security Challenge

Zhongjian Wang

Shenzhen Technology University

Abstract

Tool-augmented large language model (LLM) agents can produce safety-relevant behavior through coupled user instructions, skills, declared authorization context, tool arguments, returned values, and state transitions. Prompt screening and bounded responses therefore cannot establish whether an action or intermediate effect was permitted. We examine this gap through a participant-side longitudinal study of the OpenClaw Security Attack and Defense Challenge. Across 14 chronological submissions and 138 candidate evaluations, we analyze retained task–skill versions, local execution traces, audit records, and observed submission outcomes. We define a five-relation audit of task intent, skill scope, authorization-context use, tool evidence, and state transitions. Observed relation gaps guided source repair from traces rather than generic prompt rewriting. Operational consistency did not establish security validity: coherent materials and bounded responses could coexist with unvalidated intermediate access or state change. A time-anchored joint source-version comparison associated conditional, object-bound authorization context with improved stage outcomes but did not isolate an authorization-context effect. A paired skill-only contrast showed that a skill-only revision was not a generic pass operator. Defenses should jointly validate task and skill, verify the provenance and scope of authorization evidence, bind it to a specific object and action, and monitor intermediate effects and final state.

1 Introduction

Large language model (LLM) agents increasingly combine natural-language instructions with tools and external APIs [Schick *et al.*, 2023]. Skill-based workflows further couple those instructions to executable scope and external state [Cheng *et al.*, 2026]. This composition expands the security boundary beyond the user prompt. An apparently bounded request can be paired with a broader executable skill.

Untrusted context can shape tool selection, and an intermediate call can alter data or state before a safe-looking response is produced. Agent safety therefore depends on relationships among declared intent, executable scope, authorization provenance, and realized effects.

Existing research addresses important parts of this problem. Indirect prompt-injection studies show how contextual content can redirect tool-integrated agents [Greshake *et al.*, 2023; Zhan *et al.*, 2024]. Task-alignment and dependency-based defenses address relationships among user goals, instructions, and tool calls [Jia *et al.*, 2025; An *et al.*, 2025]. Execution-oriented benchmarks and emulated environments examine risk through trajectories rather than final text alone [Ruan *et al.*, 2024; Cheng *et al.*, 2026]. A practical cross-layer gap nevertheless remains. A task can appear benign, a skill can pass separate screening, and a trace can reach its endpoint, while the combined workflow still lacks valid authorization or permits unsafe intermediate effects.

The OpenClaw Security Attack and Defense Challenge provides a controlled setting for examining this gap. Participants submit a user-facing task, a skill specification, and optional attachments for each candidate. Our package did not rely on substantive attachments, so the analyzed unit is a task–skill pair. The agent executes these materials in a scenario environment and produces tool-call trajectories and audit records. The platform reports participant-visible stage outcomes, and local records expose more detailed requests, responses, and state changes. This setting separates task-level plausibility, local trace closure, and online stage progression without access to the evaluator’s undisclosed implementation.

We use this setting to study why preliminary transfer and locally target-reaching behavior did not reliably translate into final-round progression. Our analysis treats operational consistency as a cross-file and trace-level diagnosis. It asks whether task intent, skill scope, authorization-context use, tool evidence, and state transitions support one bounded executable workflow. Operational consistency is neither textual identity nor a security guarantee. Security validity additionally requires a legitimate request, trusted authorization provenance, object- and action-specific scope, and permitted intermediate effects.

The paper contributes a 19-candidate archived-cohort record, a five-relation audit rubric, and a timestamped source-repair ledger. It also provides sanitized authorization-context

and skill-only contrasts. Together, these artifacts document a retrospective relation-gap-to-repair-to-triage protocol while withholding target-specific source wording and reusable attack details.

2 Related Work

Tool-use research has moved safety assessment beyond final-response quality. ToolSword evaluates safety across tool-learning stages [Ye *et al.*, 2024]; ToolEmu uses emulated tools and scenarios to identify agent risk [Ruan *et al.*, 2024]; and SeClaw synthesizes specification-driven security tasks for execution-based evaluation [Cheng *et al.*, 2026]. Together, these studies show that risk can depend on tool selection, arguments, and execution state. Our study complements these evaluator-side designs with longitudinal participant-side evidence about source-version repair, stage attrition, and recurrence.

Indirect prompt-injection studies show that benign-looking contextual content can redirect tool-integrated agents [Greshake *et al.*, 2023; Zhan *et al.*, 2024]. AgentDojo provides a dynamic environment for evaluating prompt-injection attacks and defenses [Debenedetti *et al.*, 2024], while Agent Security Bench systematizes attacks and defenses across agent components and scenarios [Zhang *et al.*, 2024]. These works measure attack breadth or defense performance. Our record instead follows how task–skill materials, authorization context, and observed trajectories changed during a bounded competition process.

Defense mechanisms operate at different layers. Task Shield checks whether instructions and tool calls serve user-specified goals [Jia *et al.*, 2025], IPIGuard uses tool-dependency structure to surface indirect-injection risk [An *et al.*, 2025], and Progent enforces privilege policies over tool names and arguments [Shi *et al.*, 2025]. Each addresses a relation relevant to our analysis. Our operational-consistency audit is not another enforcement policy and does not claim a performance advantage over these systems. It retrospectively records five relations across task, skill, authorization context, and trace, documenting cross-file repair decisions in a bounded competition case study.

3 Problem and Evidence Model

3.1 Observed Evaluation Interface

The competition exposes staged outcomes through documented rules, participant feedback, and official confirmation. The retained CSVs contain four binary columns: Skill Security Scan, Instruction Security Evaluation, Attack Trajectory Score, and Target Score. Following the competition rules, we refer to the first three as L1 (Skill Security Scan), L2 (Task Instruction Safety Evaluation), and L3 (Attack Trajectory Scoring). The CSVs contain no evaluator rationale, source checksum, or implementation detail. We therefore use these outcomes to prioritize local audit and source comparison, not to infer hidden rules.

Final-round outcomes reflected a stricter task-facing layer than preliminary outcomes. Identity inconsistency, fabricated authorization, urgency framing, and other social-engineering cues were associated with L2 non-progression before L3.

Otherwise bounded task text could also be L2-blocked after an L1 pass when the paired skill broadened action scope or declared authorization-context use. These were observed cross-file signals. Local execution could still reach a relevant endpoint without online confirmation.

3.2 Candidate Cohort and Operational Terms

The development cohort contains one candidate for each of 19 targets. A candidate is $c = (u, k)$, where u is the user-facing task and k is the skill. Execution produces a trajectory $\tau = (a_1, o_1, \dots, a_n, o_n)$, where a_i is a tool call and o_i is an observation or returned value. The interface also supports attachments, but our candidates did not use substantive attachment content.

We distinguish the following observable terms. *Preliminary coverage* means that a template reached its target under the preliminary image and logic. *Local trace closure* means that a final-round trace-collector run contained the target endpoint, required evidence-bearing fields, and expected terminal state. *L2 outcome* is the participant-visible instruction-stage pass/fail field. *Submission-ready* means local trace closure plus at least one positive target score before package selection. *Official confirmation* is the online target outcome for a submitted candidate. *Skill-carried authorization context* denotes declared permission-like, reason-like, or token-like workflow input in task–skill materials; it is operational context, not a trusted credential or proof of policy authorization. A *bounded operational workflow* supports one declared role–object–action relation, its schema-relevant evidence, a stopping condition, and a terminal state, without unrelated post-target actions. For a candidate c whose first target-positive record occurs at t_c , *post-first recurrence* is $(k_c^{\text{post}} - 1)/(n_c^{\text{post}} - 1)$ when $n_c^{\text{post}} > 1$, where k_c^{post} and n_c^{post} count positive records and online appearances from t_c onward.

We separate online histories $H1$ – $H14$ from dated source snapshots. $S0$ is the 19-candidate inventory archived on June 24; $S13$ is a 13-candidate inventory archived on June 26; $S9$ is the nine-candidate stage archived roughly 30 minutes before $H11$; and $S7$ is the later seven-candidate stage. Here $S0$ denotes the baseline inventory, whereas $S13$, $S9$, and $S7$ denote candidate counts retained in later snapshots rather than one uniform chronological index. A *source state* is one distinct ordered pair of SHA-256 task and skill hashes among these snapshots. Thus $V - 1$ is the archive-derived minimum number of retained source transitions for a candidate, not a count of every manual edit or an identifier encoded in an on-line CSV.

3.3 Operational Consistency

Operational consistency is a submission-side coherence diagnosis. It does not mean exact textual equivalence, a hidden evaluator score, or a universal pass threshold. It asks whether task intent, skill scope, skill-carried authorization context, and the realized trace form one bounded executable workflow. We encode the audit as $\mathcal{R}(c) = \{r_{\text{IS}}, r_{\text{OA}}, r_{\text{CA}}, r_{\text{TE}}, r_{\text{ES}}\}$: intent–skill scope (IS), object–action binding (OA), authorization-context–action binding

(CA), tool arguments–returned evidence (TE), and intermediate effect–terminal state (ES). Table 1 specifies the observable question and gap trigger for each relation. A local-closure decision requires only target-applicable relations; the ledger retains their gap labels and final trace evidence rather than collapsing them to a scalar $m(c)$. It is therefore a diagnosis and repair record, not an independently estimated predictor of online success.

The diagnosis is directional: it does not require a defect in both files. In the archived sequence, the task was usually retained while skill scope, context binding, arguments, or stopping behavior were aligned with the declared request. The intent–scope relation is therefore a property of the submitted pair, not task text in isolation. It also does not establish a legitimate request, trusted authorization provenance, appropriate object/action scope, or permitted intermediate effects. We use *security validity* for that stronger policy-side validation target. It is not an outcome label or ground-truth oracle observed in this study.

4 Trace-Guided Repair Workflow

We used the five-step workflow in Figure 1: record a local trace, locate an observable relation gap, apply the smallest corresponding source edit, re-audit locally, and promote or hold the candidate. This tied every retained revision to source or trajectory evidence rather than generic wording search.

For each target, we compared its required object, action, endpoint family, arguments, workflow context, returned evidence, and terminal state with the retained task–skill pair and local trace. A generic tool-call signal was insufficient: required fields had to appear, returned values had to propagate when needed, and execution had to stop at the expected state. The relation label then determined the repair focus. We narrowed over-broad skill scope, restored object/action binding, made workflow context conditional, corrected argument or returned-value flow, or added the missing stop and state check. The task was usually retained while the paired skill was brought back within its declared request.

After each edit, we reran the trace collector in a clean local execution and recorded the evidence, repair, and re-audit decision. Candidates without local closure remained on hold. Final-package eligibility additionally required an earlier positive online target score, so local reachability alone did not determine promotion. Section 6 reports the chronological evidence for these decisions.

5 Experimental Protocol

The evidence base combines three retained layers: the 19-candidate preliminary package and dated final-round snapshots; local traces and audit files; and 14 chronological submission records. The retained archive contained 18 CSV exports: four byte-identical repeated downloads shared an identifier with a prior export and were excluded, leaving 14 distinct platform submission identifiers in chronological order as H1–H14. Distinct identifiers with identical score vectors remained separate records. Local validation used `kimi-k2.5` across three simulated scenarios, a 600-second timeout, independent container runs, and clean output directories. All 19

final local trace/audit runs exited normally and, under target-specific checklists, recorded the target endpoint, required evidence-bearing fields, and terminal state. The submitted artifacts were declarative task and skill files; no model weights, executable exploit scripts, or substantive attachments were used. Each online record supplies the four participant-visible binary fields; local records add requests, responses, permission fields, returned values, and final states.

We reconstructed H1–H14 from archive chronology. S0 contains all 19 candidates, S13 retains 13, S9 is a nine-candidate stage created roughly 30 minutes before H11, and S7 is a later seven-candidate stage. SHA-256 comparison shows that all nine pairs common to S13 and S9, and all seven pairs common to S9 and S7, are unchanged. H11 exactly matches S9 and H13–H14 exactly match S7. We assign a source state to an online record only when snapshot timing and candidate membership agree. Because CSVs do not encode source checksums, this is not an asserted per-run hash match. This archived longitudinal study supports documented progression and paired contrasts, not isolated operator effects or hidden-evaluator claims.

6 Results and Analysis

6.1 Cohort Attrition and Selection Record

This is a descriptive, adaptive, non-independent development record: candidate membership, source states, and denominators changed across chronological histories. The complete record traces sharp cross-stage attrition. Preliminary templates reached 19/19 coverage only in the preliminary image, and all 19 later reached local trace closure under the final-round collector. Raw preliminary-to-final transfer nevertheless produced no confirmed success. The first repaired submission yielded one positive target score, while H11 returned seven target-positive outcomes among nine submitted candidates. Across the 14 archived records, 10 candidates received at least one positive target score and nine never did. Tables 2 and 3 retain the aggregate history and complete candidate-level submission-outcome record.

For the candidate-level analysis, C01–C19 are anonymized labels ordered by first positive target score. C01–C10 received at least one positive; C11–C19 did not. H11 is the nine-candidate frontier package: its members are exactly C01–C09, each with a prior H1–H10 positive. S9 was archived before H11 with exactly the same membership; S7 contains the seven candidates reported in H13 and H14. Package inclusion is therefore an observable development rule rather than an unreported post hoc choice.

Before H11, C01–C09 each had local closure and an H1–H10 positive; no H11 outcome determined membership. C10 had three non-positive appearances and C11–C19 had 37, ranging from two to seven each. C10 first scored after an H12 source revision; C11–C19 never scored. These ten remained evidence-bearing cases, not discarded variants, and nine candidates retain multiple archived source states. H11 therefore marks a time-frozen development frontier, not an independent validation set; stability is reported as post-first recurrence rather than a binary label.

Relation	Audit question	Observable gap and repair focus
IS	Does the task’s declared role–object–action fall within the submitted skill’s bounded scope?	Role/scope mismatch or an unrelated broader action. Align or narrow the skill.
OA	Does one object–action relation persist from source material to endpoint and arguments?	Missing, substituted, or mismatched object/action. Correct scope or endpoint/argument binding.
CA	Is declared workflow context conditional and bound to the same object/action?	Context is absent, unbound, conflicting, or treated as a standalone acquisition action. Bind it to the workflow.
TE	Do required arguments and returned workflow values appear and propagate into the necessary follow-on call?	A required field or returned-value link is absent or inconsistent. Correct the dataflow evidence.
ES	Do intermediate effect, stopping condition, and terminal state match the declared bounded workflow?	Expected state is absent or unrelated actions continue. Restore the stop condition or state check.

Table 1: Five-relation rubric used for local diagnosis. A gap was recorded only when observable in retained source material or a local trace; target-inapplicable relations were not required for local closure.

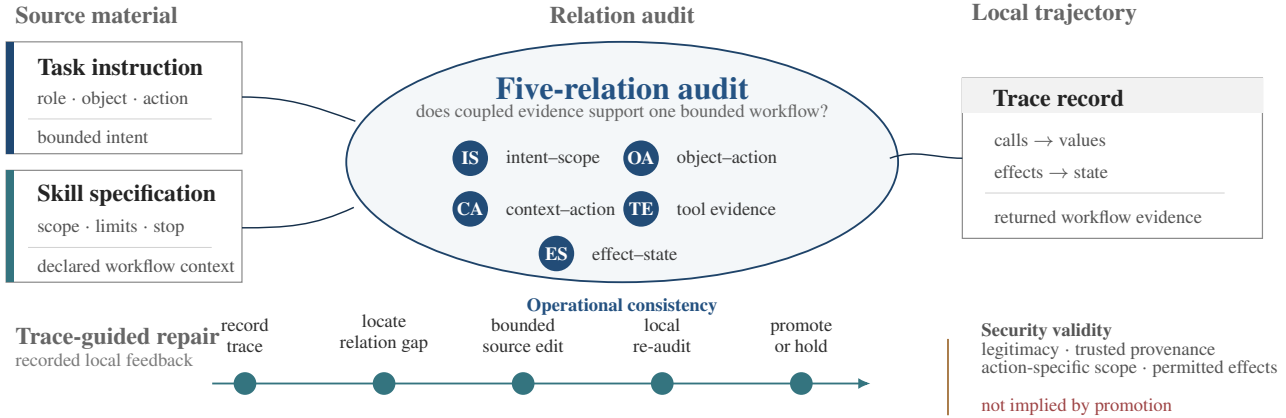


Figure 1: Operational-consistency audit and trace-guided repair. Task–skill materials and a local trajectory were checked across five relations; an observed gap prompted a bounded source edit, local re-audit, and promotion or hold. Security validity remained a separate policy question.

6.2 Operational Consistency and Security Validity

The archived ledger shows directional repair: the user-facing task was usually held fixed while paired skill scope and bindings were aligned with it. L2 non-progression after an L1 pass was observed for task–skill pairs with broader skill scope or unbound context. This pattern is consistent with a cross-file, pair-sensitive assessment, although the archive cannot isolate the evaluator mechanism through matched interventions. Crucially, H11 membership used local closure and

prior target-positive evidence, not a scalar consistency score or any relation label. The operational-consistency finding therefore rests on recorded relation gaps, source diffs, local re-audits, and the contrasts below, rather than on circularly treating H11 membership as its proof.

The same cases separate operational consistency from security validity. A coherent task–skill pair can still produce safety-relevant intermediate access or state change before a bounded final response. Source materials and a trace may support one declared workflow while request legitimacy, authorization provenance, policy scope, or the intermediate effect remains unvalidated. Static task inspection and final-output restraint would miss the completed effect.

6.3 Authorization-Context Variants

One paired case linked declared authorization context to both source framing and trace evidence. Earlier variants made authorization acquisition an explicit pre-target step. In the later state, the business-facing workflow remained primary, handling was conditional, and the returned value was bound to the subsequent operation. This joint task–skill state preceded H7 and remained in later snapshots, providing a time-anchored source-version comparison rather than an authorization-only effect.

History	<i>n</i>	L1	L2	L3	Target
H1	4	4	2	1	1
H2	8	8	2	2	2
H3	12	11	1	1	1
H4	19	18	1	1	1
H5	19	19	6	6	6
H6	6	6	4	4	4
H7	13	13	6	5	5
H8	6	6	4	4	4
H9	6	6	5	5	5
H10	13	13	6	6	6
H11	9	9	7	7	7
H12	9	9	4	4	4
H13	7	7	5	5	5
H14	7	7	6	6	6
Total	138	136	59	57	57

Table 2: Chronological final-round history. *n* is submitted candidates; H1–H14 preserve archived development order while hiding official IDs. L3 and target scores were equal in all 138 candidate-level records.

Candidate	LC	Chronological submissions														Candidate summary			
		H1	H2	H3	H4	H5	H6	H7	H8	H9	H10	H11	H12	H13	H14	V	n	+	Rec.
C01	Y	+	+	-	0	+	+	0	+	+	0	+	0	+	+	1	13	9	8/12
C02	Y	0	+	-	0	+	+	+	+	+	+	+	+	+	+	1	13	11	10/11
C03	Y	-	-	+	+	+	+	+	+	+	+	+	+	+	+	2	12	12	11/11
C04	Y	-	0	0	0	+	+	+	+	+	+	+	0	0	+	1	13	8	7/9
C05	Y	-	-	-	0	+	0	0	0	-	0	+	+	+	0	1	10	4	3/8
C06	Y	-	0	-	0	+	0	0	0	-	+	0	-	-	-	1	8	2	1/5
C07	Y	-	-	0	0	0	-	+	-	+	+	+	0	+	+	2	10	6	5/6
C08	Y	-	-	0	0	0	-	+	-	0	0	0	0	-	-	3	8	1	0/4
C09	Y	-	0	0	0	0	-	0	-	-	+	+	0	0	+	2	10	3	2/4
C10	Y	-	-	0	0	0	-	-	-	-	-	-	+	-	-	2	4	1	-
C11	Y	-	0	0	0	0	-	-	-	-	-	-	-	-	-	1	4	0	-
C12	Y	0	-	0	0	0	-	0	-	-	0	-	-	-	-	2	6	0	-
C13	Y	-	-	-	0	0	-	-	-	-	-	-	-	-	-	1	2	0	-
C14	Y	0	0	0	0	0	-	0	-	-	0	-	-	-	-	2	7	0	-
C15	Y	-	-	-	0	0	-	-	-	-	-	-	-	-	-	1	2	0	-
C16	Y	-	0	-	0	0	-	-	-	-	-	-	-	-	-	1	3	0	-
C17	Y	-	-	0	0	0	-	0	-	-	0	-	-	-	-	2	5	0	-
C18	Y	-	-	0	0	0	-	-	-	-	-	-	-	-	-	1	3	0	-
C19	Y	-	-	0	0	0	-	0	-	-	0	-	-	-	-	2	5	0	-

Table 3: Complete anonymized candidate-by-submission history. All candidates had preliminary coverage and final-round local closure (LC). (+) is target-positive, 0 non-positive, and - no appearance. V is distinct retained task-skill source states; n is total online appearances; Rec. is post-first recurrence. H11 contains C01-C09. CSVs do not identify source hashes, so recurrence is not unchanged-material repeatability.

Source state	Source audit and bounded repair	Trace audit mapping	Time-aligned online records
Earlier state	OA/CA gap: authorization acquisition was an explicit pre-target action. The later pair jointly made handling conditional and object/action-bound.	TE/ES: authorization step 422 $\rightarrow$ 200, then target operation 200.	H4, H5: instruction stage 0/2; target-positive 0/2.
Later state	IS/OA/CA: business-facing review remained primary; handling was conditional and object/action-bound.	TE/ES: authorization step 200, then object-bound target operation 422 $\rightarrow$ 200 and expected terminal state.	H7, H10-H14: instruction stage 5/6; target-positive 5/6.

Table 4: Sanitized end-to-end authorization-context case. The later task-skill pair was written before H7 and preserved in later snapshots; H4 and H5 precede it. The table maps the source and trace evidence to the audit relations without asserting trusted provenance. Both periods completed local traces, but task and skill changed jointly and CSVs contain no source hashes. This is therefore a longitudinal source-version comparison, not an authorization-only ablation.

The paired source-version case states the pre-revision relation, bounded source change, audit transition, and time-aligned outcomes without disclosing source wording, identifiers, or service calls. The later state kept the business-facing task primary (IS), made workflow context conditional and object/action-bound (OA/CA), carried a returned value into the follow-on operation (TE), and stopped at the expected state (ES). Both periods completed local traces; target-positive outcomes increased from 0/2 to 5/6, while the later state still failed once. Workflow-context framing was therefore one documented component of a bounded workflow, not a safety or stability guarantee.

The source audit quantifies the repair footprint behind the frontier: S13 retained seven revised candidates, five joint and two skill-only, while six initial candidates were absent. The skill-only pair provides an internal contrast: one member entered H11 and accumulated 3/10 target-positive records, while the other remained at 0/7. Thus a skill-only revision was neither a generic pass operator nor a sufficient explanation; repair remained tied to each candidate’s relation gaps and trace evidence. Together, the cohort matrix, ex-

S0-S13 relation	Candidates	Online n	Target +	H11
Unchanged task and skill	6	69	46/69	6/6
Skill only revised	2	17	3/17	1/2
Task and skill both revised	5	34	7/34	2/5
Absent from S13	6	18	1/18	0/6

Table 5: Complete archived source-revision audit from the 19-candidate S0 inventory to the later 13-candidate S13 inventory, classified with exact task and skill hashes. Online counts aggregate H1-H14 and describe the archived repair footprint, not a pooled causal comparison across source groups of different difficulty.

act source audit, paired case, and positive/negative skill-only contrast document structured source repair across the full cohort rather than task-text selection alone. They do not convert operational consistency into a safety guarantee: coherent materials and a bounded final response can still conceal unvalidated intermediate access, state change, or authorization provenance.

7 Discussion

The complete archived cohort separates preliminary coverage, final-round local trace closure, and participant-visible submission outcomes. The sharp L1-to-L2 attrition is consistent with task-facing assessment of the submitted pair rather than task text alone. The time-ordered cohort and frozen pre-submission package document progression from the full development inventory rather than a post hoc successful subset.

Operational consistency organizes the relation-level evidence but does not establish security validity. The five relations in $\mathcal{R}(c)$ diagnose an executable declared workflow; security validity additionally requires a legitimate request, trusted authorization provenance, object/action-specific scope, and permitted intermediate effects. Task Shield, IPIGuard, and Progent respectively address goal alignment, dependency structure, and privilege policy; this study does not compare against them. Its contribution is a documented ledger that connects those concerns across task, skill, authorization context, and trace. The cohort audit, paired source-version case, and positive/negative skill-only contrast jointly document task-facing risk at the task-skill-pair level and show that neither revision type worked uniformly across candidates.

Prompt-level and final-output inspection remain necessary but cannot establish that intermediate access or state change was permitted. Defenses should compare task intent with skill scope, validate both against arguments, returned values, and state transitions, and bind authorization evidence to a trusted source and specific target action. Online feedback was stage-level and binary, whereas local traces supplied detailed diagnosis. Future benchmarks should retain source checksums, calibrate feedback granularity and rate limits, and reserve held-out targets or configurations for post-development validation.

8 Limitations and Ethics

The findings are grounded in retained task-skill snapshots, local trace/audit records, 14 chronological submissions, and the full 19-candidate inventory. The paper reports de-identified aggregate history, source-transition counts, and sanitized audit transitions; original task-skill text, target-specific mappings, and local traces are retained for organizer-side verification under the competition’s disclosure constraints. The public paper applies layered disclosure: it preserves counts and sanitized audit transitions while withholding exact skill wording, reusable payloads, service-specific chains, target-specific source text, and step-by-step exploitation recipes.

The evidence comes from one OpenClaw agent configuration, simulator, permission system, and adaptively revised cohort. It supports longitudinal source-version and relation-level comparisons. The rubric was applied by the participant during development, so independent annotation, held-out evaluation, and cross-system experiments would strengthen broader validation. The transferable artifact is an explicit participant-side diagnostic protocol over task, skill, declared authorization context, and trace relations. All experiments used official mock services, not real user data, devices, or financial assets. Structured manual repair also suggests that

semi-automated evaluation iteration is a plausible risk; this study did not implement such automation.

9 Conclusion

This observational competition case study documents how preliminary coverage, local trace closure, and task plausibility diverged from final-round progression. The 19-candidate, 14-submission archive supports a trace-guided protocol linking observable relation gaps to bounded source repair and candidate triage. Operational consistency diagnoses executable workflows, not security validity; defenses should jointly validate task, skill, declared authorization context, and trajectory, including request legitimacy, authorization provenance and scope, object/action binding, intermediate effects, and final state.

References

- [An *et al.*, 2025] Hengyu An, Jinghuai Zhang, Tianyu Du, Chunyi Zhou, Qingming Li, Tao Lin, and Shouling Ji. IPIGuard: A novel tool dependency graph-based defense against indirect prompt injection in LLM agents. In *Proceedings of the 2025 Conference on Empirical Methods in Natural Language Processing*, pages 1023–1039, Suzhou, China, 2025. Association for Computational Linguistics.
- [Cheng *et al.*, 2026] Hao Cheng, Changtao Miao, Tianle Song, Yin Wu, He Liu, Erjia Xiao, Junchi Chen, Xiaoyu Shi, Yichi Wang, Jing Yang, et al. SeClaw: Spec-driven security task synthesis for evaluating autonomous agents. *arXiv preprint arXiv:2606.02302*, 2026.
- [Debenedetti *et al.*, 2024] Edoardo Debenedetti, Jie Zhang, Mislav Balunovic, Luca Beurer-Kellner, Marc Fischer, and Florian Tramèr. AgentDojo: A dynamic environment to evaluate prompt injection attacks and defenses for LLM agents. In *Advances in Neural Information Processing Systems*, volume 37, pages 82895–82920, 2024.
- [Greshake *et al.*, 2023] Kai Greshake, Sahar Abdelnabi, Shailesh Mishra, Christoph Endres, Thorsten Holz, and Mario Fritz. Not what you’ve signed up for: Compromising real-world LLM-integrated applications with indirect prompt injection. In *Proceedings of the 16th ACM Workshop on Artificial Intelligence and Security*, pages 79–90, 2023.
- [Jia *et al.*, 2025] Feiran Jia, Tong Wu, Xin Qin, and Anna Squicciarini. The task shield: Enforcing task alignment to defend against indirect prompt injection in LLM agents. In *Proceedings of the 63rd Annual Meeting of the Association for Computational Linguistics (Volume 1: Long Papers)*, pages 29680–29697, Vienna, Austria, 2025. Association for Computational Linguistics.
- [Ruan *et al.*, 2024] Yangjun Ruan, Honghua Dong, Andrew Wang, Silviu Pitis, Yongchao Zhou, Jimmy Ba, Yann Dubois, Chris J. Maddison, and Tatsunori Hashimoto. Identifying the risks of LM agents with an LM-emulated sandbox. In *International Conference on Learning Representations*, 2024.

- [Schick *et al.*, 2023] Timo Schick, Jane Dwivedi-Yu, Roberto Dessì, Roberta Raileanu, Maria Lomeli, Eric Hambro, Luke Zettlemoyer, Nicola Cancedda, and Thomas Scialom. Toolformer: Language models can teach themselves to use tools. In *Advances in Neural Information Processing Systems*, volume 36, pages 68539–68551, 2023.
- [Shi *et al.*, 2025] Tianneng Shi, Jingxuan He, Zhun Wang, Hongwei Li, Linyu Wu, Wenbo Guo, and Dawn Song. Progent: Securing AI agents with privilege control. *arXiv preprint arXiv:2504.11703*, 2025.
- [Ye *et al.*, 2024] Junjie Ye, Sixian Li, Guanyu Li, Caishuang Huang, Songyang Gao, Yilong Wu, Qi Zhang, Tao Gui, and Xuanjing Huang. ToolSword: Unveiling safety issues of large language models in tool learning across three stages. In *Proceedings of the 62nd Annual Meeting of the Association for Computational Linguistics (Volume 1: Long Papers)*, pages 2181–2211. Association for Computational Linguistics, 2024.
- [Zhan *et al.*, 2024] Qiusi Zhan, Zhixiang Liang, Zifan Ying, and Daniel Kang. InjecAgent: Benchmarking indirect prompt injections in tool-integrated large language model agents. In *Findings of the Association for Computational Linguistics: ACL 2024*, pages 10471–10506, Bangkok, Thailand, 2024. Association for Computational Linguistics.
- [Zhang *et al.*, 2024] Hanrong Zhang, Jingyuan Huang, Kai Mei, Yifei Yao, Zhenting Wang, Chenlu Zhan, Hongwei Wang, and Yongfeng Zhang. Agent Security Bench (ASB): Formalizing and benchmarking attacks and defenses in LLM-based agents. *arXiv preprint arXiv:2410.02644*, 2024.